CASE STUDY

ProFTPD mod_copy, CVE-2015-3306: Unauthenticated File Copy in the Lab

A TeamStarWolf case study. Published 4 November 2026; every source checked as of that date.

Executive summary

ProFTPD is a long-lived open-source FTP server packaged by Debian, Ubuntu, Fedora and SUSE, among others. Its optional mod_copy module adds two SITE commands, CPFR ("copy from") and CPTO ("copy to"), that copy a file from one path on the server to another. In April 2015 a researcher, Vadim Melihow, found that the module answered both commands before the client had logged in. Anyone who could reach the FTP port could copy any file the daemon could read to any place the daemon could write, with no account at all. The project fixed it on 7 April 2015, the day Bug 4169 was filed, shipped the fix in ProFTPD 1.3.5a on 27 May 2015, and the flaw became CVE-2015-3306.

For eleven years this was a solved problem with public exploits. Then, on 8 October 2026, CISA added it to the Known Exploited Vulnerabilities catalog with a three-day due date and a forensic-triage requirement, on the same day that ten agencies in seven countries published joint advisory AA26-281A, which lists CVE-2015-3306 in its table of 'Successfully Exploited CVEs', compiled from the penetration-testing scripts of actors enabled by a China-based company. That listing is why the flaw is back on defenders' desks, and it is why this study exists.

The lab run behind this study, on 4 November 2026, ran two container builds side by side: one from the ProFTPD source just before the fix, one from the fix merge itself. The vulnerable build copied a file for an unauthenticated client and wrote it to disk as the daemon user; the fixed build refused with a login prompt. The run also turned up three things a defender needs to know that the original plan did not predict: the two builds report the same version banner, the lab images' default logs record nothing about the attack, and the open Suricata ruleset has no rule for it.

> Evidence grade: the flaw, the fix and the KEV listing are **Confirmed**; the public exploits and the lab results are **Demonstrated**; the Metasploit description of the code-execution path is **Reported**; any tie between a specific intrusion and this CVE is **Inferred**, because no opened source dates one.

Key facts at a glance

Field	Value
Identifier	CVE-2015-3306; ProFTPD Bug 4169; GitHub advisory GHSA-4mfj-5wr8-x32q
Class	Missing authentication check on the SITE CPFR and SITE CPTO commands in mod_copy; CWE-284 Improper Access Control
Severity	NVD CVSS v2 10.0 (AV:N/AC:L/Au:N/C:C/I:C/A:C); CVSS v3.1 10.0 Critical from the CISA ADP container, not from NVD; CISA SSVC (9 October 2026): exploitation active, automatable, technical impact total
Vendor ratings	Ubuntu Medium; SUSE critical
Access required	Network access to the FTP control port; no login; mod_copy must be compiled in or loaded, which the vendor says is not the default
Affected	ProFTPD 1.3.5 (NVD), its release candidates (the original report shows 1.3.5rc3), and the development branch before the fix
Worst outcome	Arbitrary file read and write as the daemon's runtime user; PHP code execution when a payload is copied into a web root (Reported, Metasploit)
Fix	A login check returning 530, merged 7 April 2015; released in 1.3.5a (27 May 2015) and 1.3.6rc1
Public exploits	Exploit-DB 36742 (13 April 2015), Exploit-DB 36803 (21 April 2015), Metasploit module (disclosure date 22 April 2015)
KEV	Added 8 October 2026, due 11 October 2026, ransomware use Unknown, forensic triage required
In the wild	Listed in AA26-281A Appendix B as successfully exploited, from scripts in a penetration-testing tool; no dated intrusion or named victim
Lab result	Demonstrated 4 November 2026: vulnerable build answers 350 and "250 Copy successful", fixed build answers 530

Key findings

- **One missing check, full file-system reach.** Before the fix, mod_copy already required a login for SITE COPY but not for SITE CPFR and SITE CPTO (**Confirmed** [6]). The fix commit's own message says the module "inadvertently" allowed unauthenticated copying (**Confirmed** [4]). The lab reproduced the result: an unauthenticated session copied `/etc/hostname` to a new file in `/tmp`, owned by `nobody:nogroup` (**Demonstrated** [36]).
- **The fix was fast; the long tail was not.** The fix was written in the early hours of 7 April 2015 (UTC). Bug 4169 was filed at 16:35, the fix was merged twelve minutes later and backported to the 1.3.5 branch by 16:55 (**Confirmed** [3][4][5]). Public exploits followed within two weeks (**Demonstrated** [14][15]). Eleven years later the flaw entered KEV with a three-day due date (**Confirmed** [22][23]).

- **The 2026 exploitation record is real but thin.** AA26-281A lists CVE-2015-3306 under "Successfully Exploited CVEs" for actors enabled by Integrity Technology Group, whose activity the advisory calls consistent with Flax Typhoon, Ethereal Panda and Red Juliett (**Confirmed** [24]). The same advisory says those CVEs were recovered from penetration-testing scripts and does not date a ProFTPD intrusion or name a victim, so any claim about a specific intrusion is **Inferred** [24].
- **The banner cannot tell you whether you are fixed.** Both lab builds announced `220 ProFTPD 1.3.6rc1 Server`, and `proftpd -V` printed the same version for both (**Demonstrated** [36]). Distribution backports keep old version strings too (**Inferred** from [17][18]). Only the package version from your vendor, or the server's behaviour, answers the question.
- **The lab images' default logging was blind to the attack.** On both builds the container log showed only a startup line and, per connection, a mod_delay notice and session-open and session-close lines, with no trace of SITE CPFR, SITE CPTO or the copy, and /var/log/proftpd in the vulnerable container was empty (**Demonstrated** [36], `02-test.txt`). The open Emerging Threats Suricata ruleset contains no rule matching CPFR or the CVE (**Confirmed** [29]).
- **1.3.5a is not the end of the mod_copy story.** CVE-2019-12815, a related arbitrary-file-copy flaw in mod_copy, affects ProFTPD up to 1.3.5b (**Confirmed** [20]), so a host that stopped at 1.3.5a and still loads mod_copy remains in scope for the later flaw (**Inferred** from [20]).

Top recommendations

1. **Find every ProFTPD that has mod_copy.** Run `proftpd -l` on each host and look for `mod_copy.c`, and check DSO configurations for a mod_copy load line. Do not rely on a package query: the lab's source build under `/usr/local` was invisible to `dpkg -l` (**Demonstrated** [36]).
2. **Upgrade to your vendor's fixed package, or to a current upstream release.** Use the fixed versions in Part 5 for Debian, Ubuntu and SUSE. For source builds, move to a current release (the project listed 1.3.9e and 1.3.10rc5 on 4 November 2026 [27]) rather than 1.3.5a, because of CVE-2019-12815 [20].
3. **Turn the module off where nobody uses it.** On 1.3.5a and later, `CopyEngine off` disables mod_copy at runtime (**Confirmed** [4][9][10]); on any version, not building or loading the module removes it. A `<Limit SITE_CPFR SITE_CPTO>` deny block is a further option the vendor's command naming supports, but the lab did not test any of these workarounds (**Inferred** [11][12][36]).
4. **Treat a KEV-listed FTP server as a possible incident, not only a patch.** CISA's required action points to its forensic-triage requirements (**Confirmed** [22][23]). Look for files owned by the FTP runtime user in web roots and temporary directories, and assume the default logs will not show the copy (the file ownership and the empty default logs are **Demonstrated** [36]; the hunt itself is **Inferred**).
5. **Build the detection you need, because none ships by default.** Alert on SITE CPFR or SITE CPTO sent before a 230 login reply, and on 350 or "250 Copy successful" sent to an unauthenticated session; these rule designs are **Inferred** and untested [36].

Scope and method

This study covers CVE-2015-3306 from the 2015 report to the 2026 KEV listing, the lab run of 4 November 2026, and what a defender should do about it today. It does not cover CVE-2019-12815 beyond noting its overlap, and it does not reproduce or quote any exploit code. Exploit-class steps from the lab are described in prose; version checks and the server's differing replies are quoted from the capture files. Sources are the ProFTPD project's own bug tracker, source history and release notes, NVD, the CVE Program record, CISA's KEV catalog and joint advisory AA26-281A, the Debian, Ubuntu and SUSE trackers, and the lab captures. Every source was opened on 4 November 2026.

Grade	Meaning
Confirmed	A primary source was opened: the vendor's bug tracker, source history or release notes, NVD or the CVE record, a distribution tracker, or a government advisory
Reported	A secondary source only, not independently checked against a primary
Demonstrated	A public reproduction exists (Exploit-DB, Metasploit), or the lab run of 4 November 2026 showed it; the lab capture file is named
Inferred	The study's own reasoning from the sources, labelled as such

About the figures

The four screenshots are renderings of real command output captured on a lab host on 4 November 2026 UTC (container log timestamps 04:06 to 04:07), with a neutral `lab$` prompt; the host kernel line is removed and the lab account name is replaced with a neutral user. The targets were two containers run from Docker images published by VulnCheck, bound to the loopback address only, and removed afterwards. The capture of the exploit-class test steps is not shown, and in the mitigation screenshot the copy command is replaced by a one-line description; the results are quoted line by line in Part 4.

Part 1: the flaw

What mod_copy does

mod_copy gives an FTP client a way to copy a file on the server without downloading and re-uploading it. It adds SITE COPY, which takes a source and a destination in one command, and the pair SITE CPFR and SITE CPTO, which take them in two steps: CPFR names the source and the server answers that it is ready for a destination, then CPTO names the destination and the server performs the copy (**Confirmed** [1][10]; the 350 reply is **Demonstrated** [36], `02-test.txt`). The copy runs inside the FTP daemon, so it can read whatever the daemon's runtime user can read and write wherever that user can write (**Reported** [16]; **Demonstrated** [36]).

The vendor's documentation says mod_copy "is not compiled by default" (**Confirmed** [10]). It is built in with `./configure --with-modules=mod_copy`, built as a loadable module with `--enable-dso --with-shared=mod_copy`, or added to an existing installation with the `prxs` tool [10]. Exposure therefore depends on how a given ProFTPD was built or packaged, which is the first thing a defender has to establish.

The bug

In the pre-fix source, SITE COPY checked that the session was authenticated, but the CPFR and CPTO handlers did not (**Confirmed** [6]). The server answers these commands before login, so an unauthenticated client could send the two-step pair and the server would carry out the copy (**Demonstrated** [36]). The fix commit, written by TJ Saunders on 7 April 2015, says the module "inadvertently allows unauthenticated copying" and notes that it had no Engine directive with which an administrator could switch it off (**Confirmed** [4]).

NVD describes the result as letting remote attackers read and write arbitrary files through the SITE CPFR and SITE CPTO commands (**Confirmed** [1]). Read access follows because a file the attacker cannot download can be copied to a place the attacker can reach; write access follows because the destination is the attacker's choice (**Inferred**).

The impact path to code execution

On its own the flaw copies files that already exist. The path to code execution that the Metasploit module describes is to get attacker-controlled text into a file the daemon can read, then copy that file into a web server's document root under a name the web server will execute. The Metasploit module's description says the copy runs with the ProFTPD service's rights, by default the `nobody` user, and that copying `/proc/self/cmdline` holding a PHP payload into the web directory gives PHP code execution (**Reported** [16]). The original Bug 4169 report also shows a PHP file being placed in a web root (**Confirmed** [3]; not quoted). The lab deliberately did not demonstrate this path.

Weakness, severity and scoring

- **Weakness.** NVD and the CISA ADP container list CWE-284 Improper Access Control. In the CVE Program record the original CNA entry from MITRE says "n/a", and CWE-284 comes only from the CISA ADP container (**Confirmed** [1][2]). The KEV entry and AA26-281A also carry CWE-284 [22][24].
- **Severity.** NVD's own score is CVSS v2 10.0 with vector AV:N/AC:L/Au:N/C:C/I:C/A:C. The CVSS v3.1 10.0 Critical score, vector AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H, is the CISA ADP's Secondary score; NVD has no v3 score of its own for this CVE (**Confirmed** [1]).
- **SSVC.** CISA's SSVC 2.0.3 decision, dated 9 October 2026, records exploitation active, automatable yes, and technical impact total (**Confirmed** [1]).
- **Vendor ratings disagree.** Ubuntu rates the issue Medium; SUSE rates it critical (**Confirmed** [18][19]). The difference may reflect how each vendor packages mod_copy and weighs exposure, and a program should record the vendor rating next to the base score rather than pick one (**Inferred**).

Affected versions

NVD's affected configurations list the ProFTPD 1.3.5 CPE plus Fedora 20, 21 and 22, Debian 7, 8 and 9, openSUSE Tumbleweed and SUSE Linux Enterprise Server 15 SP7 (**Confirmed** [1]). The reporter's transcript in Bug 4169 shows a `ProFTPD 1.3.5rc3 Server (Debian)` banner, so the 1.3.5 release candidates were affected as well (**Confirmed** [3]). The Debian tracker says squeeze was not affected because mod_copy is not part of ProFTPD 1.3.3 (**Confirmed** [17]). The lab's vulnerable image is a third case: a build of the development branch just before the fix, which reports itself as 1.3.6rc1 (Part 4).

The fix

The fix adds an authentication check to the CPFR and CPTO handlers that answers `530` to a session that has not logged in, adds a `CopyEngine on|off` directive so the module can be disabled at runtime without recompiling, raises the module version from mod_copy/0.4 to mod_copy/0.5, and adds regression tests that send the commands without logging in (**Confirmed** [4][5]). It reached users in ProFTPD 1.3.5a, released 27 May 2015, whose NEWS file lists Bug 4169 by name, and in 1.3.6rc1 (**Confirmed** [8][3]). The module documentation gives CopyEngine's compatibility as 1.3.6rc1 and later, but the 1.3.5a source already contains both the directive and the 530 check (**Confirmed** [9][10]).

The related flaw: CVE-2019-12815

In 2019 a second mod_copy flaw was published: CVE-2019-12815, an arbitrary file copy in mod_copy in ProFTPD up to 1.3.5b, which NVD describes as a related issue to CVE-2015-3306 (NVD CVSS v3.1 9.8, CWE-755) (**Confirmed** [20]). The practical point is that 1.3.5a fixes CVE-2015-3306 but is not a complete answer for mod_copy: a host that upgraded to 1.3.5a or 1.3.5b and stopped is still in scope for the later flaw (**Inferred** from [8][20]).

Part 2: the timeline

Date (UTC unless noted)	Event	Grade	Source
7 Apr 2015, 00:14	Fix commit 35b65aaf72 (author date) adds the 530 login check and the CopyEngine directive	Confirmed	[4]
7 Apr 2015, 16:35	Bug 4169 filed by TJ Saunders, reporting Vadim Melihow's finding that mod_copy allows SITE CPFR/CPTO by unauthenticated clients; version 1.3.5, severity critical	Confirmed	[3]
7 Apr 2015, 16:41	Pull request #109, "Bug#4169 - Unauthenticated copying of files via SITE CPFR/CPTO allowed by mod_copy", opened	Confirmed	[5]
7 Apr 2015, 16:47:19	PR #109 merged as commit 3ef395d81327558e6e6def43df9138b1cd4955dd (parents 4c3cd1d1a1a1 and 35b65aaf7219)	Confirmed	[5]
7 Apr 2015, 16:55	Bug 4169: fix merged to master and backported to the 1.3.5 branch	Confirmed	[3]
13 Apr 2015	Exploit-DB 36742, "ProFTPd 1.3.5 File Copy", published; it reproduces the Bug 4169 report	Demonstrated	[14]
15 Apr 2015	CVE-2015-3306 reserved in the CVE Program record; Bug 4169 notes the CVE assigned the same day	Confirmed	[2][3]
15 Apr 2015, 02:39 +0200	Hanno Boeck discloses the flaw on oss-security, linking PR #109, Bug 4169 and cxsecurity WLB-2015040075, and noting no upstream release with a fix exists yet	Confirmed	[13]
21 Apr 2015	Exploit-DB 36803, a weaponized remote command execution exploit for ProFTPD 1.3.5 with mod_copy, published (recorded, not quoted)	Demonstrated	[15]
22 Apr 2015	Disclosure date of Metasploit module `exploit/unix/ftp/proftpd_modcopy_exec` (developers Vadim Melihow and xistence)	Reported	[16]
18 May 2015	CVE-2015-3306 published	Confirmed	[1][2]
19 May 2015	Debian DSA-3263-1 fixes proftpd-dfsg in wheezy (1.3.4a-5+deb7u3), jessie (1.3.5-1.1+deb8u1) and unstable (1.3.5-2, Debian bug 782781)	Confirmed (via the Debian tracker; the DSA page itself returned a challenge page on 4 November 2026)	[17]
27 May 2015	ProFTPD 1.3.5a released; NEWS lists Bug 4169	Confirmed	[8]
28 May 2015	Bug 4169: resolved in 1.3.5a and 1.3.6rc1; status CLOSED FIXED	Confirmed	[3]
19 Jul 2019	Related flaw CVE-2019-12815 published (mod_copy, ProFTPD up to 1.3.5b)	Confirmed	[20]

Date (UTC unless noted)	Event	Grade	Source
13 May 2022	GHSA-4mfj-5wr8-x32q published to the GitHub Advisory Database (unreviewed, High, no package or version ranges)	Confirmed	[21]
8 Oct 2026	CISA adds CVE-2015-3306 to KEV as "ProFTPD Improper Access Control Vulnerability"; due 11 October 2026; forensic triage Yes	Confirmed	[22][23]
8 Oct 2026	Joint advisory AA26-281A released; lists CVE-2015-3306 under Affected Products and in Appendix B Table 16, "Successfully Exploited CVEs"	Confirmed	[24]
8 Oct 2026	GHSA-4mfj-5wr8-x32q updated	Confirmed	[21]
9 Oct 2026	CISA SSVC decision recorded (active, automatable, total); NVD record last modified	Confirmed	[1]
9 Oct 2026	A security newsletter ties the KEV add to AA26-281A	Reported	[26]
4 Nov 2026	Lab run: vulnerable build copies a file without login; fixed build refuses with 530	Demonstrated	[36]

Two intervals in the table carry the lesson. Twelve minutes passed between the bug being filed and the fix being merged, and twenty between filing and the 1.3.5 backport. The first public exploit came six days after the fix, two days before the oss-security disclosure, and the first upstream release that contained the fix came about six weeks after that (**Inferred**, arithmetic on the dated rows). The KEV due date is three days after the add (**Confirmed** [22]).

Part 3: who exploited it

The KEV listing

The KEV JSON feed (catalog version 2026.11.03) lists CVE-2015-3306 as "ProFTPD Improper Access Control Vulnerability", added 8 October 2026, due 11 October 2026, with known ransomware campaign use Unknown, forensic triage Yes, and CWE-284. Its required action cites BOD 26-04 and CISA's Forensics Triage Requirements (**Confirmed** [22]). The catalog page for the CVE shows "Forensic triage required per BOD 26-04" (**Confirmed** [23]). This study did not open the directive's text, so what the triage requirement asks of an agency in detail is not checked.

Joint advisory AA26-281A

AA26-281A was released on 8 October 2026, the day of the KEV add, by the FBI, CISA, NSA, the UK's NCSC, Australia's ASD's ACSC, the Canadian Centre for Cyber Security, Japan's NPA and NCO, New Zealand's NCSC and Spain's CNI (**Confirmed** [24]). It lists CVE-2015-3306 under Affected Products, and in Appendix B, Table 16, "Successfully Exploited CVEs", as ProFTPD 1.3.5, CWE-284, vulnerability type "Unauthorized read", with the asterisk the table uses for CVEs newly added to KEV (**Confirmed** [24]).

Who. The advisory says the actors are enabled by Integrity Technology Group, a China-based company with links to the Chinese government, and calls their tactics, techniques and procedures consistent with activity

publicly known as Flax Typhoon, Ethereal Panda and Red Juliett, while noting that vendor tracking may not map one to one (**Confirmed** [24]). ATT&CK has no group object for Flax Typhoon: the groups index has no such entry, and G1007 is Aoqin Dragon (**Confirmed** [25]). This study therefore binds no ATT&CK group id to these actors.

How. The advisory says the actors focus their scanning on ports 21 (FTP), 22, 53, 80, 443 and 1080, and use dirsearch to enumerate PHP and ASP pages, which it tags T1595.002 (**Confirmed** [24]). A scan that finds both an FTP server and PHP pages on the same host is exactly the pairing the mod_copy code-execution path needs, but the advisory does not draw that connection (**Inferred**).

The caution. The advisory says the CVEs in Table 16 were recovered from penetration-testing scripts, from a tool it calls MicroScan, used since as early as 2017 and holding over 1,300 scripts (**Confirmed** [24]). It does not date a ProFTPD intrusion, name a ProFTPD victim, or say how many hosts were hit. The defensible reading (**Inferred**) is that these actors' tooling carries a CVE-2015-3306 script and that the authoring agencies counted it as successfully exploited; tying any specific intrusion to this CVE is **Inferred** [24].

Beyond AA26-281A

Two searches found no honeypot, botnet or ransomware report that ties CVE-2015-3306 to a named campaign beyond AA26-281A, and the KEV ransomware field reads Unknown (**Inferred** from an absence [22]). A search-result summary of a consultancy page linking Flax Typhoon to SSH and database credential theft through this CVE was not opened and is not supported by AA26-281A, so this study does not use it. A newsletter published the day after the KEV add tied the listing to AA26-281A (**Reported** [26]); the primary advisory was opened and is what this study cites.

What the public record does show is a mature exploit ecosystem that has been available to anyone since April 2015: a file-copy proof of concept, a weaponized command-execution exploit, a Metasploit module (**Demonstrated** [14][15]; **Reported** [16]), and a nuclei scanner template that tests by performing a copy (**Confirmed** [28]).

Part 4: what the lab showed

The lab run used two images from VulnCheck's ProFTPD series, one built from commit `4c3cd1d1a1a1` (the last commit before the fix) and one from the fix merge `3ef395d81327`, each in its own container with the FTP port published on the loopback address only: `cve-2015-3306-vuln` on 127.0.0.1:2121 and `cve-2015-3306-fixed` on 127.0.0.1:2122 (**Demonstrated** [36], `01-setup.txt`). The image digests begin `sha256:c9d48275` (vulnerable) and `sha256:2d196c2d` (fixed).

CVE-2015-3306 - setup (vulnerable + patched ProFTPD containers)

```
lab$  docker pull vulncheck/proftpd:vcai.4c3cd1d1a1a1.9f49c9.5c03a5550210.v
vcai.4c3cd1d1a1a1.9f49c9.5c03a5550210.v: Pulling from vulncheck/proftpd
7fd1ebe418b5: Pulling fs layer
4069885c284f: Pulling fs layer
f4fb4fc75260: Pulling fs layer
3f4120039de9: Pulling fs layer
4336f322236c: Pulling fs layer
3f4120039de9: Waiting
4336f322236c: Waiting
4069885c284f: Verifying Checksum
4069885c284f: Download complete
f4fb4fc75260: Verifying Checksum
f4fb4fc75260: Download complete
3f4120039de9: Verifying Checksum
3f4120039de9: Download complete
4336f322236c: Download complete
7fd1ebe418b5: Verifying Checksum
7fd1ebe418b5: Download complete
7fd1ebe418b5: Pull complete
4069885c284f: Pull complete
f4fb4fc75260: Pull complete
3f4120039de9: Pull complete
4336f322236c: Pull complete
Digest: sha256:c9d48275c9d86a6ea4b8835cffe68149b0520319d60580b057b499ab402765b6
Status: Downloaded newer image for vulncheck/proftpd:vcai.4c3cd1d1a1a1.9f49c9.5c03a5550210.v
docker.io/vulncheck/proftpd:vcai.4c3cd1d1a1a1.9f49c9.5c03a5550210.v

lab$  docker pull vulncheck/proftpd:vcai.3ef395d81327.9f49c9.b870e4268495.p
vcai.3ef395d81327.9f49c9.b870e4268495.p: Pulling from vulncheck/proftpd
7fd1ebe418b5: Already exists
4069885c284f: Already exists
5a1ade9efc88: Pulling fs layer
2ae8ce7c1498: Pulling fs layer
397ff22d93c7: Pulling fs layer
397ff22d93c7: Verifying Checksum
397ff22d93c7: Download complete
2ae8ce7c1498: Verifying Checksum
2ae8ce7c1498: Download complete
5a1ade9efc88: Verifying Checksum
5a1ade9efc88: Download complete
5a1ade9efc88: Pull complete
2ae8ce7c1498: Pull complete
397ff22d93c7: Pull complete
Digest: sha256:2d196c2d5f4ccbec0c8a679bdcc23973ee48f72c77c834d1d784b696a89fb645
Status: Downloaded newer image for vulncheck/proftpd:vcai.3ef395d81327.9f49c9.b870e4268495.p
docker.io/vulncheck/proftpd:vcai.3ef395d81327.9f49c9.b870e4268495.p

lab$  docker run -d --name cve-2015-3306-vuln -p 127.0.0.1:2121:21 vulncheck/proftpd:vcai.4c3cd1d1a1a1.9f49c9.5c03a5
7f8f13084877b3803ba408bcfa72e8fd56c4f4e3d2cbfb886de1dcc46ad89873

lab$  docker run -d --name cve-2015-3306-fixed -p 127.0.0.1:2122:21 vulncheck/proftpd:vcai.3ef395d81327.9f49c9.b870e
0ae07d42a521c1cfccb57f10e13e3c891a31c64a8a91ed1f941370126cc23430

lab$  docker ps --filter name=cve-2015-3306 --format 'table {{.Names}}\t{{.Status}}\t{{.Ports}}'
NAMES                 STATUS         PORTS
cve-2015-3306-fixed   Up 5 seconds   127.0.0.1:2122->21/tcp
cve-2015-3306-vuln    Up 5 seconds   127.0.0.1:2121->21/tcp

lab$  docker exec cve-2015-3306-vuln sh -c 'P=$(command -v proftpd || ls /usr/local/sbin/proftpd /usr/sbin/proftpd 2
Compile-time Settings:
  Version: 1.3.6rc1 (git)
  Built: Tue Oct 20 2026 02:23:48 UTC
  Built With:
  mod_copy.c
/etc/proftpd/proftpd.conf:# mod_copy is compiled in and enabled by default
```

The precondition was met

In the vulnerable container, `proftpd -V` reports `Version: 1.3.6rc1 (git)` with the configure line `'--prefix=/usr/local' '--with-modules=mod_copy'`, and `proftpd -l` lists `mod_copy.c` (**Demonstrated** [36], `03-exposure.txt`). The module is compiled in statically, so it is active without any load directive.

Finding 1: the banner cannot tell the builds apart

The plan expected a ProFTPD 1.3.5 banner. Both builds instead sent the same greeting, `220 ProFTPD 1.3.6rc1 Server (ProFTPD Default Installation)`, and `proftpd -V` reports `1.3.6rc1 (git)` for both (**Demonstrated** [36], `02-test.txt`, `03-exposure.txt`). The only differences visible without testing behaviour were the build times, 35 seconds apart (02:23:48 and 02:24:23 UTC on 20 October 2026).

The source explains why. At the pre-fix commit `4c3cd1d1a1a1`, `include/version.h` already defines the version text as `1.3.6rc1`, and that commit is the first parent of the fix merge (**Confirmed** [7][5]). The vulnerable image is the development branch a moment before the fix, not a 1.3.5 release. For a defender the lesson generalizes: a version string tells you which line of code a build came from, not whether a given fix is in it.

Finding 2: the read-only probe separates them

The plan's read-only probe, graded Inferred before the run, sends SITE CPFR on its own, without logging in and without a CPTO, so no copy can happen. The first attempt returned nothing, because the netcat client closed its input before the server's banner arrived (the empty output is **Demonstrated** [36], `02-test.txt`; the cause is **Inferred**); a re-run that waited for the banner produced the replies (**Demonstrated** [36], `02-test.txt`). The vulnerable build answered:

```
350 File or directory exists, ready for destination name
```

The fixed build answered:

```
530 Please login with USER and PASS
```

That one reply code is the cleanest behavioural test for the flaw (**Demonstrated** [36], `02-test.txt`).

Finding 3: the copy works without a login, as the daemon user

The test then sent the CPFR and CPTO pair without logging in, asking each server to copy `/etc/hostname` to a marker file under `/tmp`. The vulnerable build answered `350` and then `250 Copy successful`; the fixed build answered `530 Please login with USER and PASS` to both commands (**Demonstrated** [36], `02-test.txt`).

Inside the vulnerable container the marker file existed, 13 bytes long, holding the container's hostname and owned by the daemon's runtime user:

```
-rw-r--r-- 1 nobody nogroup 13 Nov  4 04:07 /tmp/lab-cve-2015-3306-marker
```

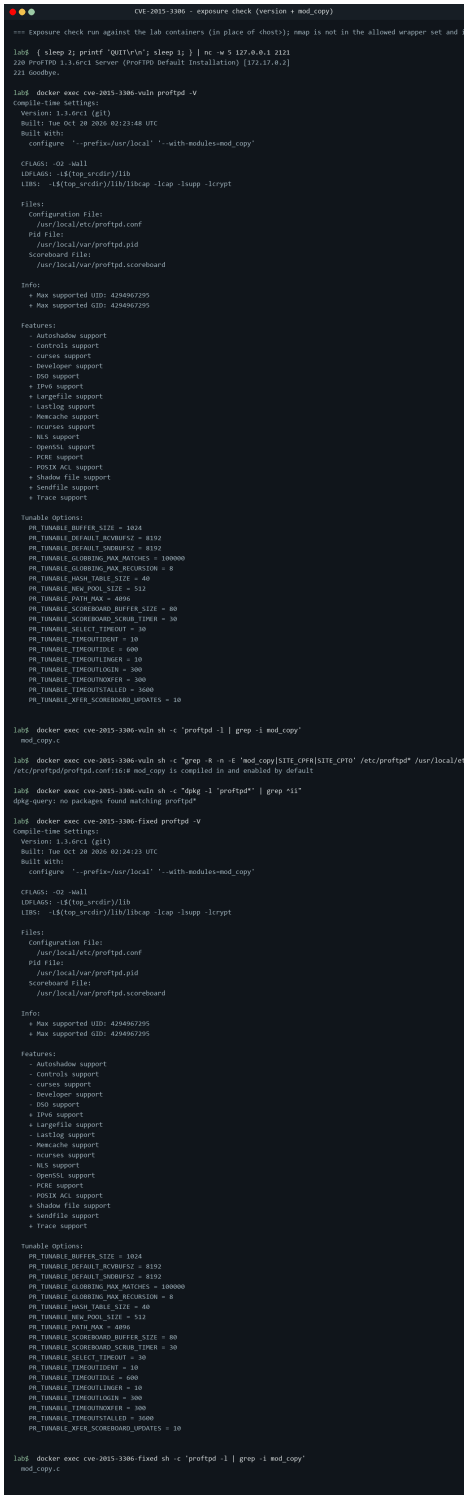
In the fixed container, `ls` reported `No such file or directory` for the same path (**Demonstrated** [36], `02-test.txt`, `04-mitigation.txt`). The file's owner is the useful detail: anything this flaw writes belongs to the FTP daemon's runtime user, which gives a host-side hunting signal.

Finding 4: the default logs record nothing

The plan expected the host logs to show the SITE commands. They did not. On both builds, `docker logs` showed a startup line and, for each connection, only a mod_delay notice, `FTP session opened.` and `FTP session closed.`, with no record of SITE CPFR, SITE CPTO or the copy, and `/var/log/proftpd` inside the vulnerable container was empty (**Demonstrated** [36], `02-test.txt`). A successful unauthenticated file write left no trace in the daemon's default logging.

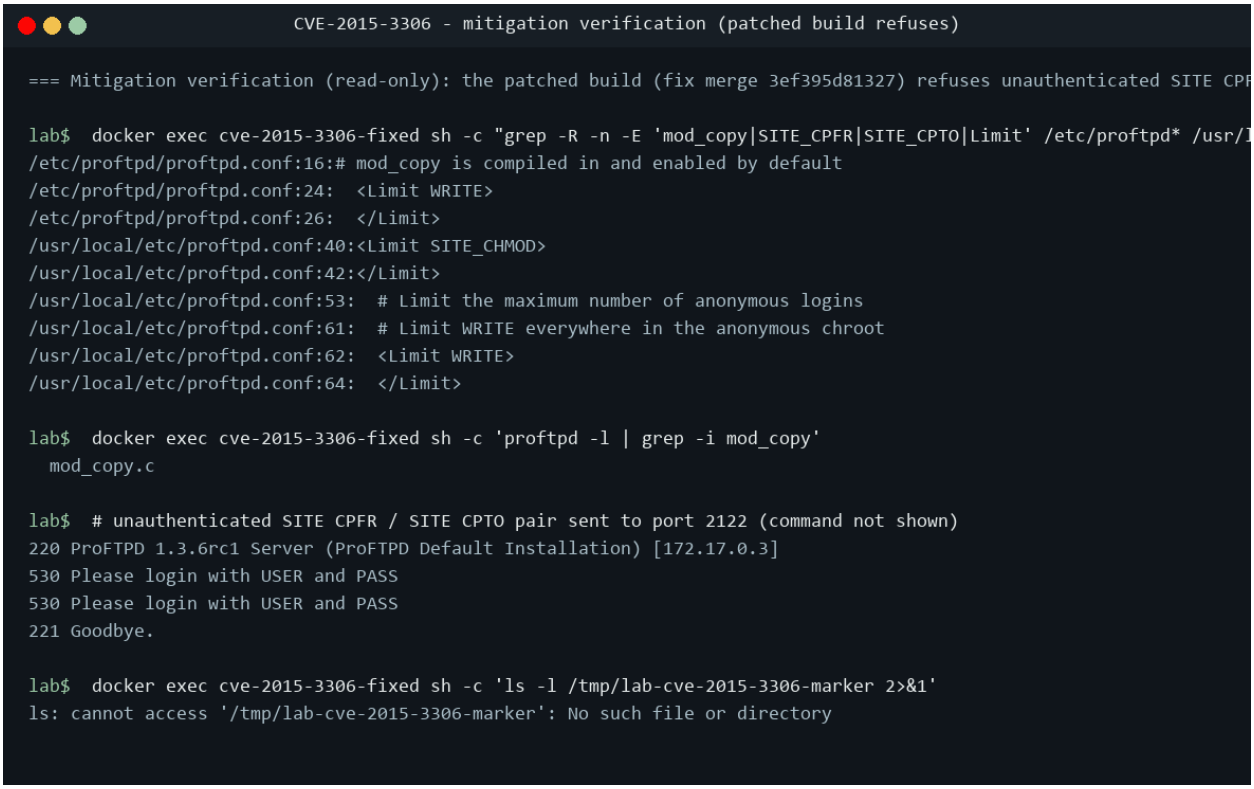
Finding 5: a package query misses source builds

Inside the vulnerable image, `dpkg -l 'proftpd*'` returned `no packages found`, because the daemon is a source build under `/usr/local` with its configuration at `/usr/local/etc/proftpd.conf` (**Demonstrated** [36], `03-exposure.txt`). An asset inventory built only from package managers would have reported no ProFTPD on this host. A configuration search found only the comment `# mod_copy is compiled in and enabled by default` at `/etc/proftpd/proftpd.conf` line 16, and no `SITE_CPFR` or `SITE_CPTO` limit block. A network scan with nmap was not run.


CVE-2015-3306 - exposure check (version + mod_copy)
=== Exposure check run against the lab containers (in place of <host>); nmap is not in the allowed wrapper set and
lab$ { sleep 2; printf 'QUIT\r\n'; sleep 1; } | nc -w 5 127.0.0.1 2121
220 ProFTPD 1.3.6rc1 Server (ProFTPD Default Installation) [172.17.0.2]
221 Goodbye.
lab$ docker exec cve-2015-3306-vuln proftpd -V
Compile-time Settings:
Version: 1.3.6rc1 (git)
Built: Tue Oct 20 2026 02:23:48 UTC
Built with:
configure '--prefix=/usr/local' '--with-modules=mod_copy'
CFLAGS: -O2 -Wall
LDFLAGS: -L$(top_srcdir)/lib
LIBS: -L$(top_srcdir)/lib/libcap -lcap -lsupp -lcrypt
Files:
Configuration File:
/usr/local/etc/proftpd.conf
Pid File:
/usr/local/var/proftpd.pid
Scoreboard File:
/usr/local/var/proftpd.scoreboard
Info:
+ Max supported UID: 4294967295
+ Max supported GID: 4294967295
Features:
- Autoshadow support
- Controls support
- curses support
- Developer support
- DSO support
+ IPv6 support
+ Largefile support
- Lastlog support
- Memcache support
- ncurses support
- NLS support
- OpenSSL support
- PCRE support
- POSIX ACL support
+ Shadow file support
+ Sendfile support
+ Trace support
Tunable Options:
PR_TUNABLE_BUFFER_SIZE = 1024
PR_TUNABLE_DEFAULT_RCVBUFSZ = 8192
PR_TUNABLE_DEFAULT_SNDBUFSZ = 8192
PR_TUNABLE_GLOBBING_MAX_MATCHES = 100000
PR_TUNABLE_GLOBBING_MAX_RECURSION = 8
PR_TUNABLE_HASH_TABLE_SIZE = 40
PR_TUNABLE_NEW_POOL_SIZE = 512
PR_TUNABLE_PATH_MAX = 4096
PR_TUNABLE_SCOREBOARD_BUFFER_SIZE = 80
PR_TUNABLE_SCOREBOARD_SCRUB_TIMER = 30
PR_TUNABLE_SELECT_TIMEOUT = 10
PR_TUNABLE_TIMEOUTIDENT = 10
PR_TUNABLE_TIMEOUTIDLE = 600
PR_TUNABLE_TIMEOUTLINGER = 10
PR_TUNABLE_TIMEOUTLOGIN = 300
PR_TUNABLE_TIMEOUTNOXFER = 300
PR_TUNABLE_TIMEOUTSTALLED = 3600
PR_TUNABLE_XFER_SCOREBOARD_UPDATES = 10
lab$ docker exec cve-2015-3306-vuln sh -c 'proftpd -l | grep -i mod_copy'
mod_copy.c
lab$ docker exec cve-2015-3306-vuln sh -c "grep -R -n -E 'mod_copy|SITE_CPFR|SITE_CPTO' /etc/proftpd* /usr/local/et
/etc/proftpd/proftpd.conf:16:# mod_copy is compiled in and enabled by default
lab$ docker exec cve-2015-3306-vuln sh -c "dpkg -l 'proftpd*' | grep ^ii"
dpkg-query: no packages found matching proftpd*
lab$ docker exec cve-2015-3306-fixed proftpd -V
Compile-time Settings:
Version: 1.3.6rc1 (git)
Built: Tue Oct 20 2026 02:24:23 UTC
Built with:
configure '--prefix=/usr/local' '--with-modules=mod_copy'
CFLAGS: -O2 -Wall
LDFLAGS: -L$(top_srcdir)/lib
LIBS: -L$(top_srcdir)/lib/libcap -lcap -lsupp -lcrypt
Files:
Configuration File:
/usr/local/etc/proftpd.conf
Pid File:
/usr/local/var/proftpd.pid
Scoreboard File:
/usr/local/var/proftpd.scoreboard
Info:
+ Max supported UID: 4294967295
+ Max supported GID: 4294967295
Features:
- Autoshadow support
- Controls support
- curses support
- Developer support
- DSO support
+ IPv6 support
+ Largefile support
- Lastlog support
- Memcache support
- ncurses support
- NLS support
- OpenSSL support
- PCRE support
- POSIX ACL support
+ Shadow file support
+ Sendfile support
+ Trace support
Tunable Options:
PR_TUNABLE_BUFFER_SIZE = 1024
PR_TUNABLE_DEFAULT_RCVBUFSZ = 8192
PR_TUNABLE_DEFAULT_SNDBUFSZ = 8192
PR_TUNABLE_GLOBBING_MAX_MATCHES = 100000
PR_TUNABLE_GLOBBING_MAX_RECURSION = 8
PR_TUNABLE_HASH_TABLE_SIZE = 40
PR_TUNABLE_NEW_POOL_SIZE = 512
PR_TUNABLE_PATH_MAX = 4096
PR_TUNABLE_SCOREBOARD_BUFFER_SIZE = 80
PR_TUNABLE_SCOREBOARD_SCRUB_TIMER = 30
PR_TUNABLE_SELECT_TIMEOUT = 10
PR_TUNABLE_TIMEOUTIDENT = 10
PR_TUNABLE_TIMEOUTIDLE = 600
PR_TUNABLE_TIMEOUTLINGER = 10
PR_TUNABLE_TIMEOUTLOGIN = 300
PR_TUNABLE_TIMEOUTNOXFER = 300
PR_TUNABLE_TIMEOUTSTALLED = 3600
PR_TUNABLE_XFER_SCOREBOARD_UPDATES = 10
lab$ docker exec cve-2015-3306-fixed sh -c 'proftpd -l | grep -i mod_copy'
mod_copy.c

Finding 6: the mitigation that was verified is the code fix

The fixed container still has mod_copy compiled in, and its configuration has no SITE_CPFR or SITE_CPTO limit (only `<Limit WRITE>` and `<Limit SITE_CHMOD>` blocks), yet it refuses both commands with `530` and no marker file appears (**Demonstrated** [36], `04-mitigation.txt`). The refusal comes from the patched code, not from configuration. The configuration workarounds (a `<Limit SITE_CPFR SITE_CPTO>` deny block, `CopyEngine off`, or not loading the module) and any file-integrity or Wazuh alert were not tested in the lab and are not recorded in the captures (**Inferred** [36], `plan.json`).



Cleanup

Both containers and both images were removed, `docker ps -a --filter name=cve-2015-3306` returned no rows, and the working directory `/tmp/lab/CVE-2015-3306/` was deleted (**Demonstrated** [36], `05-cleanup.txt`). A separate container from the Ghostcat lab run (the Ghostcat case study) was still up at that moment, which the listing shows.

CVE-2015-3306 - cleanup

```
lab$  docker rm -f cve-2015-3306-vuln cve-2015-3306-fixed
cve-2015-3306-vuln
cve-2015-3306-fixed

lab$  docker rmi vulncheck/proftpd:vcai.4c3cd1d1a1a1.9f49c9.5c03a5550210.v vulncheck/proftpd:vcai.3ef395d81327.9f49c
Untagged: vulncheck/proftpd:vcai.4c3cd1d1a1a1.9f49c9.5c03a5550210.v
Untagged: vulncheck/proftpd@sha256:c9d48275c9d86a6ea4b8835cffe68149b0520319d60580b057b499ab402765b6
Deleted: sha256:5c03a55502100e64d14adaeeff4a3b5dcc400fe6cd1d66998380afdc843dac6b
Deleted: sha256:22eb9125eb034d738c853ac2a1c5dff7c3ccb035f803f33b7cff20c87b9abccd
Deleted: sha256:bd96e94e1e9cbd14100e53e80ca881412d3317c8ed4a7f9e5bc029a5a19c4a06
Deleted: sha256:ced3547ca2954514a0548c2cd3fd82aa6064126b22751d47acdebd34748a23c8
Untagged: vulncheck/proftpd:vcai.3ef395d81327.9f49c9.b870e4268495.p
Untagged: vulncheck/proftpd@sha256:2d196c2d5f4ccbec0c8a679bdcc23973ee48f72c77c834d1d784b696a89fb645
Deleted: sha256:b870e42684957f0704c9e7eefae1e1fbca55ba49177a274f7135ef928fbaad2d
Deleted: sha256:962bf4d31631af26cafb67754dfe04f345aae25bbb2dd3214db746f86a0119dd
Deleted: sha256:596d6221f5ffbaeb9796d4fbdf691b7687c00ee556908f01059d0e36a1c06e1e
Deleted: sha256:e01f93b94adae10efccde631b8df28c5a05cdb3a66032b9d43f1486e8b579bd5
Deleted: sha256:9d268f5a088858e06bdf784f082a8fd415c8c0796375e1c9794a39985b9df854
Deleted: sha256:e58989146fcec76699871403b9897b5c014af1ccd85f5a9300a215e7975525d7

lab$  docker ps -a --filter name=cve-2015-3306; docker images vulncheck/proftpd
CONTAINER ID   IMAGE     COMMAND   CREATED   STATUS    PORTS     NAMES
REPOSITORY   TAG       IMAGE ID   CREATED   SIZE

lab$  docker ps -a
CONTAINER ID   IMAGE                  COMMAND             CREATED          STATUS          PORTS
f09e9fd6bb66   vulhub/tomcat:9.0.30   "catalina.sh run"   39 seconds ago   Up 25 seconds   127.0.0.1:8009->8009/tcp,

lab$  rm -rf /tmp/lab/CVE-2015-3306/

lab$  ls -la /tmp/lab/
total 0
drwxrwxr-x  3 user user  60 Nov  3 23:09 .
drwxrwxrwt 16 root root 820 Nov  3 23:09 ..
drwxrwxr-x  3 user user 260 Nov  3 23:09 CVE-2020-1938

lab$  docker ps -a --filter name=cve-2015-3306
CONTAINER ID   IMAGE     COMMAND   CREATED   STATUS    PORTS     NAMES
```

Part 5: how to find and fix it on real hosts

Step 1: find ProFTPD, including source builds

Start from every host that listens on TCP 21 or runs a `proftpd` process, not from the package inventory, because the lab's source build was invisible to `dpkg` (**Demonstrated** [36]). On each one, these read-only commands, all run in the lab, show the version, the build options and the built-in modules:

```
proftpd -V
proftpd -l | grep -i mod_copy
grep -R -n -E 'mod_copy|SITE_CPFR|SITE_CPTO' /etc/proftpd* /usr/local/etc/proftpd* 2>/dev/null
```

`proftpd -V` prints the configure line; in the lab it named `--with-modules=mod_copy` (**Demonstrated** [36]), and a shared build would carry `--with-shared=mod_copy` [10] (**Inferred**). `proftpd -l` lists the compiled-in

modules. A host where the binary was built as a loadable-module build may load mod_copy from its configuration instead, so the configuration search matters as well; the exact load-line file varies by distribution and was not checked.

Step 2: decide whether it is vulnerable

The banner and the version string are not reliable. Distribution backports keep the original version in the package version (for example Debian's 1.3.5-1.1+deb8u1 and Ubuntu's 1.3.5~rc3-2.1ubuntu2.1 are fixed packages), and the lab's fixed build shared the vulnerable build's banner exactly (**Inferred** from [17][18][36]). Use one of two answers:

- **The vendor package version.** Compare the installed package with the fixed versions below.
- **The server's behaviour.** On a host you are authorised to test, send SITE CPFR alone, without logging in and without a CPTO, and read the reply code: `350` means the unauthenticated copy path is open, `530` means it is closed (**Demonstrated** [36]). The probe copies nothing. The public nuclei template is not a substitute for this probe in production: it matches on "Copy successful", so it performs a real copy and is an active test (**Confirmed** [28]).

Step 3: upgrade

Platform	Fixed in	Source
Upstream source	1.3.5a (27 May 2015) and 1.3.6rc1 and later for CVE-2015-3306; current releases on 4 November 2026 were 1.3.9e and 1.3.10rc5. Prefer a current release because CVE-2019-12815 affects mod_copy up to 1.3.5b	[3][8][20][27]
Debian 7 wheezy	proftpd-dfsg 1.3.4a-5+deb7u3 (DSA-3263-1)	[17]
Debian 8 jessie	proftpd-dfsg 1.3.5-1.1+deb8u1 (DSA-3263-1)	[17]
Debian 12 bookworm	All versions in this release are fixed; the fix has been in Debian since 1.3.5-2 (unstable, bug 782781). Current packages 1.3.8+dfsg-4+deb12u5, and 1.3.8+dfsg-4+deb12u4 in bookworm-security	[17]
Debian 13 trixie	All versions in this release are fixed (fixed since 1.3.5-2 in unstable); current package 1.3.8.c+dfsg-4+deb13u3	[17]
Debian forky and sid	Fixed since 1.3.5-2 (unstable, bug 782781); current package 1.3.9e~dfsg-3	[17]
Debian 6 squeeze	Not affected (mod_copy is not in 1.3.3)	[17]
Ubuntu 12.04	proftpd-dfsg 1.3.4a-1ubuntu0.1	[18]
Ubuntu 14.04	proftpd-dfsg 1.3.5~rc3-2.1ubuntu2.1	[18]
Ubuntu 15.04	proftpd-dfsg 1.3.5-1.1+deb8u1build0.15.04.1	[18]
Ubuntu 15.10, 16.04, 16.10	Not affected	[18]
SUSE Linux Enterprise Server 15 SP7 (including the Server Applications module and SAP)	proftpd 1.3.8b-150600.13.6.1	[19]
openSUSE Tumbleweed	proftpd 1.3.5b-2.5 (openSUSE-Tumbleweed-2024-10048); the 2015 advisory is openSUSE-SU-2015:1031-1	[19]
Fedora 20, 21, 22	Listed as affected by NVD; Fedora's advisories were not opened, so fixed versions are not checked	[1]

All rows except Fedora are **Confirmed** from the tracker named. Restart the FTP service after upgrading so the running daemon is the patched one.

Step 4: if you cannot upgrade yet, or nobody uses the module

- **CopyEngine off.** On 1.3.5a and later, `CopyEngine off` in the server configuration disables mod_copy at runtime without recompiling; the directive defaults to on (**Confirmed** [4][9][10]). The directive arrived with the fix, so it does not exist on a vulnerable pre-fix build (**Inferred** from [4]). On a patched host it is still worth setting where nobody needs server-side copy, because it also closes the later mod_copy flaw's code path (**Inferred** from [20]).
- **A limit block.** ProFTPD limits SITE commands with `<Limit SITE_command>` blocks, and the current mod_copy source names its commands `SITE_CPFR` and `SITE_CPTO` for those checks (**Confirmed** [11][12]); the vendor documentation describes `<Limit SITE_COPY>` for the module (**Confirmed** [10]). A block

denying all clients these commands follows from that naming:

```
<Limit SITE_CPFR SITE_CPTO SITE_COPY>
  DenyAll
</Limit>
```

Whether this holds on a 1.3.5 build is not checked, and the lab did not test it (**Inferred** [36]).

- **Remove the module.** Rebuild without `--with-modules=mod_copy`, or remove its load line on a DSO build. This is the only workaround that does not depend on the vulnerable code honouring a directive (**Inferred** from [10]).

Verify any workaround the way the lab verified the fix: the SITE CPFR-alone probe should return a refusal, not `350`.

Step 5: detect and hunt

- **Network.** Alert on SITE CPFR or SITE CPTO on the FTP control channel before the server has sent a `230` login reply, and on a `350` or `250 Copy successful` reply to a session that has not authenticated (**Inferred** rule design from the lab replies [36]; untested). The open Emerging Threats ruleset for Suricata 7.0.3 has no rule matching CPFR or CVE-2015-3306, so this rule has to be written locally (**Confirmed** [29]).
- **Host logs.** The default configuration in the lab logged nothing useful (**Demonstrated** [36]). The current mod_copy source writes a TransferLog (xferlog) entry when it copies a file, so a configured TransferLog may record copies; the lab did not check this (**Inferred** from [11]). The module's trace channel `copy` (for example `Trace copy:20` with a TraceLog) is documented for debugging only (**Confirmed** [10]).
- **Files.** Look for new files owned by the FTP daemon's runtime user (`nobody` in the lab) in web roots and in `/tmp`, and put file-integrity monitoring on web roots that share a host with an FTP server (**Inferred** from [36][16]).
- **Forensic triage.** Because the host may have been exposed for years and the default logs are blind, treat a vulnerable, internet-facing ProFTPD with mod_copy as a host to examine, in line with the KEV listing's forensic-triage flag (**Confirmed** [22]; the scope of the examination is **Inferred**).

Part 6: the vulnerability-management view

- **The signals agree, for once.** A CVSS v2 10.0, an SSVC decision of active, automatable and total, a KEV listing with a three-day due date, a multinational advisory, and public exploits since 2015 all point the same way (**Confirmed** [1][22][24]; **Demonstrated** [14][15]). The ratings that point down are Ubuntu's Medium (**Confirmed** [18]) and GHSA's High [21]; read Ubuntu's rating as a statement about its packaging, not as a reason to defer an exposed host (**Inferred**).
- **Scope by precondition, not by product name.** The flaw needs mod_copy. The vendor leaves it out of default builds; a host where `proftpd -l` does not list it and no configuration loads it is not exposed to this CVE (**Confirmed** [10]; the scoping rule is **Inferred**). That turns a "ProFTPD everywhere" emergency into a list of specific hosts.
- **Old CVEs need the same speed as new ones.** A flaw from 2015 carried a three-day KEV due date in 2026 (**Confirmed** [22]). Patch SLAs keyed to a CVE's publication date, or to "it is too old to matter", fail on exactly this case (**Inferred**).

- **Asset inventory is the bottleneck.** The lab container's daemon was invisible to the package manager (**Demonstrated** [36]). Source builds, vendor appliances and containers carry their own copies of daemons like this one, and only a listener-first, binary-first inventory finds them (**Inferred**).
- **Fix the module, not just the CVE.** CVE-2019-12815 reaches the same module up to 1.3.5b (**Confirmed** [20]). Closing CVE-2015-3306 by moving to 1.3.5a, then closing the ticket, would leave the host exposed (**Inferred**).

What is overstated and what is understated

- **Overstated: the "Successfully Exploited" listing as a record of intrusions.** AA26-281A lists CVE-2015-3306 in a table of "Successfully Exploited CVEs" that it says was recovered from penetration-testing scripts, and it dates no ProFTPD intrusion and names no victim (**Confirmed** [24]). Reading the listing as evidence of dated intrusions goes beyond the advisory (**Inferred** [24]).
- **Understated: the blind default logs and the builds a package query misses.** The lab images' default logging recorded nothing of SITE CPFR, SITE CPTO or the copy, and the source build under `/usr/local` was invisible to `dpkg -l` (**Demonstrated** [36]). Exposure counts and hunts built on package inventories and default logs therefore undercount (**Inferred**).
- **Understated: the CVE-2019-12815 tail.** The later mod_copy flaw reaches ProFTPD up to 1.3.5b (**Confirmed** [20]), so a host fixed for CVE-2015-3306 at 1.3.5a or 1.3.5b with mod_copy loaded is still exposed (**Inferred** from [20]).

MITRE mappings

No opened source names an ATT&CK technique for CVE-2015-3306 itself: NVD, the KEV entry and the ProFTPD record carry no technique ids, and AA26-281A's technique list does not include T1190 (**Confirmed** [1][22][24]). Every binding in the first table below is therefore this study's own mapping from the verified behaviour, labelled as such, and every id was checked against the live ATT&CK page or the library's technique profiles (ATT&CK v20.0) on 4 November 2026.

ATT&CK Enterprise techniques bound to this flaw

ID	Name	Tactic	Dated event or report	Basis	Sources
T1190	Exploit Public-Facing Application	Initial Access (TA0001)	Bug 4169 (7 Apr 2015); public exploits (13 to 22 Apr 2015); KEV add and AA26-281A (8 Oct 2026); lab run (4 Nov 2026)	Inferred mapping: an unauthenticated network client abuses a listening FTP daemon; the behaviour is Demonstrated in the lab	[1][3][14][22][24][30][36]
T1005	Data from Local System	Collection (TA0009)	NVD description (published 18 May 2015); AA26-281A type "Unauthorized read" (8 Oct 2026); lab copy of `/etc/hostname` (4 Nov 2026)	Inferred mapping from the arbitrary read; the copy is Demonstrated in the lab	[1][24][31][36]
T1505.003	Server Software Component: Web Shell	Persistence (TA0003)	Bug 4169 report's web-root PHP example (7 Apr 2015); Metasploit module (22 Apr 2015)	Inferred mapping from the documented code-execution path; deliberately not demonstrated in the lab	[3][16][32]
T1595.002	Active Scanning: Vulnerability Scanning	Reconnaissance (TA0043)	AA26-281A (8 Oct 2026): scanning of port 21 among others, dirsearch for PHP and ASP pages	Confirmed in the advisory as actor behaviour; its tie to ProFTPD is Inferred	[24]

T1059.004 (Unix Shell) is left out of the bound table: AA26-281A lists it for the actors, but no primary ties it to ProFTPD or to this CVE.

Techniques AA26-281A lists for the actors, not bound to this flaw

AA26-281A lists these ATT&CK ids (cited by the advisory under ATT&CK v19) for the actors it describes (**Confirmed** [24]). Each is live in the library's v20.0 technique profiles under the name shown. They describe the actors, not CVE-2015-3306, and are not in this study's layer except T1595.002.

ID	Name (library v20.0 profile)	Tactic
T1003.006	OS Credential Dumping: DCSync	Credential Access
T1020	Automated Exfiltration	Exfiltration
T1036.003	Masquerading: Rename Legitimate Utilities	Stealth
T1059.001	Command and Scripting Interpreter: PowerShell	Execution
T1059.004	Command and Scripting Interpreter: Unix Shell	Execution
T1059.006	Command and Scripting Interpreter: Python	Execution
T1059.007	Command and Scripting Interpreter: JavaScript	Execution
T1074.001	Data Staged: Local Data Staging	Collection

ID	Name (library v20.0 profile)	Tactic
T1110.001	Brute Force: Password Guessing	Credential Access
T1110.003	Brute Force: Password Spraying	Credential Access
T1114.002	Email Collection: Remote Email Collection	Collection
T1133	External Remote Services	Persistence, Initial Access
T1189	Drive-by Compromise	Initial Access
T1560.003	Archive Collected Data: Archive via Custom Method	Collection
T1595.002	Active Scanning: Vulnerability Scanning	Reconnaissance

Groups, software and campaigns

None is bound. ATT&CK has no group object for Flax Typhoon, Ethereal Panda, Red Juliett or Integrity Technology Group, and G1007 is Aoqin Dragon, not Flax Typhoon (**Confirmed** [25]). No opened source names an ATT&CK software or campaign object for CVE-2015-3306. The Metasploit module and the Exploit-DB entries are public exploit code, not ATT&CK software objects.

Weaknesses and attack patterns

ID	Name	Basis	Sources
CWE-284	Improper Access Control (Pillar)	Listed by NVD, the CISA ADP container, KEV, AA26-281A and GHSA-4mfj-5wr8-x32q; see the CWE Reference	Confirmed [1][2][21][22][24][33]
CWE-755	Improper Handling of Exceptional Conditions	Listed by NVD for the related CVE-2019-12815, not for CVE-2015-3306	Confirmed [20]
CAPEC-650	Upload a Web Shell to a Web Server	The code-execution path; the library's CAPEC data maps it to T1505.003. No primary names a CAPEC for this CVE	Inferred [34][37]
CAPEC-563	Add Malicious File to Shared Webroot	One of the 17 CAPEC entries the library's CWE data lists under CWE-284; fits the copy-into-web-root path	Inferred [37]

D3FEND countermeasures

The library's ATT&CK-to-D3FEND data maps the bound techniques to the last four countermeasures below; Software Update and Application Configuration Hardening are added for the mitigation side. Each has a library page (**Confirmed** [35][37]; the fit to this flaw is **Inferred**).

Countermeasure	Library page	Maps from	How it applies here
D3-SU Software Update	/mitre/d3fend/software-update.md	Mitigation side	The verified fix: upgrade to a patched package or release (Part 5, Step 3)
D3-ACH Application Configuration Hardening	/mitre/d3fend/application-configuration-hardening.md	Mitigation side	`CopyEngine off`, a SITE command limit block, or building without mod_copy (Step 4)

Countermeasure	Library page	Maps from	How it applies here
D3-APCA Application Protocol Command Analysis	/mitre/d3fend/application-protocol-command-analysis.md	T1190	Watching the FTP control channel for SITE CPFR/CPTO before login (Step 5)
Inbound Traffic Filtering	/mitre/d3fend/inbound-traffic-filtering.md	T1190	Keeping TCP 21 off the internet where FTP is not a public service
D3-FIM File Integrity Monitoring	/mitre/d3fend/file-integrity-monitoring.md	T1505.003, T1005	Alerting on new files in web roots, especially those owned by the FTP user
Local File Permissions	/mitre/d3fend/local-file-permissions.md	T1505.003, T1005	Denying the FTP runtime user write access to web roots, which breaks the code-execution path

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, proftpd-mod-copy-cve-2015-3306.json on GitHub (open in Navigator), listed on the Navigator layers page. It is pinned to ATT&CK v20 (navigator 4.9, layer format 4.5) and holds the four techniques of the bound table as four technique-tactic entries. Scores separate the evidence: 100 for behaviour the lab demonstrated (T1190, T1005), 75 for the documented code-execution path the lab did not demonstrate (T1505.003), and 40 for actor context from AA26-281A that is not tied to a ProFTPD intrusion (T1595.002). Each entry's comment names the source numbers of this study's Sources table.

Cross-cutting themes

- **Age is not safety.** An eleven-year-old CVE with a same-day fix entered KEV in 2026 with a three-day due date. A scanner-script library that carries a check for an old flaw keeps it live for as long as unpatched hosts exist. See the Vulnerability Prioritization Reference.
- **Version strings describe lineage, not fixes.** The lab's vulnerable and fixed builds announced the same version, and distribution backports keep old version numbers in fixed packages. Behaviour (here, one reply code) and the vendor's package version are the only reliable answers.
- **Optional modules are where exposure hides.** mod_copy is off by default upstream, which is exactly why it is easy to forget on the hosts where a packager or an administrator turned it on. Inventory by what is compiled and loaded, not by product name.
- **Detection has to be designed.** The default logs recorded nothing, the open IDS ruleset has nothing, and the public nuclei template performs a real copy. A defender who wants to see this attack has to write the network rule and turn on the logging before it happens.
- **"Exploited" has a source, and the source matters.** AA26-281A lists CVE-2015-3306 in a 'Successfully Exploited CVEs' table that it says was recovered from an actor's penetration-testing scripts. That is a strong reason to patch and a weak basis for claiming any specific intrusion. Keeping those two claims apart is the same Confirmed-versus-Inferred discipline the rest of the library applies. See the case studies' Method.

- **Close the module, not the ticket.** CVE-2019-12815 hit the same module four years later. A fix that removes or disables an unused feature closes the next flaw in it too.

Sources

All sources were opened on 4 November 2026. Exploit code was recorded and not quoted; its URLs are given as plain text.

#	Source	URL	Opened	Grade
1	NVD, CVE-2015-3306 (description, CWE-284, CVSS v2 and the CISA ADP v3.1 score, SSVC, affected configurations, last modified 9 Oct 2026)	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2015-3306	2026-11-04	Confirmed
2	CVE Program record for CVE-2015-3306 (reserved 15 Apr 2015, published 18 May 2015; CNA entry n/a, CWE-284 from CISA ADP)	https://cveawg.mitre.org/api/cve/CVE-2015-3306	2026-11-04	Confirmed
3	ProFTPD Bugzilla, Bug 4169 (report, comments of 7 Apr, 15 Apr and 28 May 2015, status CLOSED FIXED)	http://bugs.proftpd.org/show_bug.cgi?id=4169	2026-11-04	Confirmed
4	ProFTPD fix commit 35b65aaf72 (TJ Saunders, 7 Apr 2015)	https://api.github.com/repos/proftpd/proftpd/commits/35b65aaf72	2026-11-04	Confirmed
5	ProFTPD merge commit 3ef395d81327 for PR #109 (merged 7 Apr 2015 16:47:19 UTC; the PR API's merge_commit_sha field reads db65895b0dff, so the commit API is cited for the hash)	https://api.github.com/repos/proftpd/proftpd/commits/3ef395d81327	2026-11-04	Confirmed
6	contrib/mod_copy.c at pre-fix commit 4c3cd1d1	https://api.github.com/repos/proftpd/proftpd/contents/contrib/mod_copy.c?ref=4c3cd1d1a1a188369caaf820f4e80143fb12305b	2026-11-04	Confirmed
7	include/version.h at pre-fix commit 4c3cd1d1 (version text 1.3.6rc1)	https://api.github.com/repos/proftpd/proftpd/contents/include/version.h?ref=4c3cd1d1a1a188369caaf820f4e80143fb12305b	2026-11-04	Confirmed
8	ProFTPD NEWS at v1.3.5a (released 27 May 2015, Bug 4169 listed)	https://api.github.com/repos/proftpd/proftpd/contents/NEWS?ref=v1.3.5a	2026-11-04	Confirmed
9	contrib/mod_copy.c at v1.3.5a (CopyEngine and the 530 check, mod_copy/0.5)	https://api.github.com/repos/proftpd/proftpd/contents/contrib/mod_copy.c?ref=v1.3.5a	2026-11-04	Confirmed
10	ProFTPD mod_copy documentation (not compiled by default, build options, CopyEngine, SITE_COPY limit, trace channel)	https://github.com/proftpd/proftpd/blob/master/doc/contrib/mod_copy.html	2026-11-04	Confirmed
11	contrib/mod_copy.c on master (SITE_CPFR and SITE_CPTO limit names, TransferLog entries)	https://github.com/proftpd/proftpd/blob/master/contrib/mod_copy.c	2026-11-04	Confirmed
12	ProFTPD Limit howto (SITE command limits)	https://github.com/proftpd/proftpd/blob/master/doc/howto/Limit.html	2026-11-04	Confirmed

#	Source	URL	Opened	Grade
13	Hanno Boeck, oss-security post, 15 Apr 2015	https://www.openwall.com/lists/oss-security/2015/04/15/2	2026-11-04	Confirmed
14	Exploit-DB 36742, "ProFTPd 1.3.5 File Copy" (13 Apr 2015)	`https://www.exploit-db.com/exploits/36742`	2026-11-04	Demonstrated
15	Exploit-DB 36803, remote command execution exploit for ProFTPD 1.3.5 with mod_copy (21 Apr 2015); recorded only	`https://www.exploit-db.com/exploits/36803`	2026-11-04	Demonstrated
16	Rapid7, Metasploit module `exploit/unix/ftp/proftpd_modcopy_exec` description (disclosure date 22 Apr 2015)	`https://www.rapid7.com/db/modules/exploit/unix/ftp/proftpd_modcopy_exec/`	2026-11-04	Reported
17	Debian security tracker, CVE-2015-3306 (DSA-3263-1 fixed versions, current fixed versions, squeeze not affected)	https://security-tracker.debian.org/tracker/CVE-2015-3306	2026-11-04	Confirmed
18	Ubuntu, CVE-2015-3306 (priority Medium, fixed versions)	https://ubuntu.com/security/CVE-2015-3306	2026-11-04	Confirmed
19	SUSE, CVE-2015-3306 (rated critical, SLES 15 SP7 and Tumbleweed fixed versions)	https://www.suse.com/security/cve/CVE-2015-3306.html	2026-11-04	Confirmed
20	NVD, CVE-2019-12815 (related mod_copy flaw, up to 1.3.5b)	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2019-12815	2026-11-04	Confirmed
21	GitHub Advisory Database, GHSA-4mfj-5wr8-x32q	https://github.com/advisories/GHSA-4mfj-5wr8-x32q	2026-11-04	Confirmed
22	CISA KEV JSON feed (catalog version 2026.11.03)	https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-04	Confirmed
23	CISA KEV catalog page for CVE-2015-3306	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2015-3306	2026-11-04	Confirmed
24	Joint advisory AA26-281A (8 Oct 2026), including Appendix B Table 16	https://www.cisa.gov/news-events/cybersecurity-advisories/aa26-281a	2026-11-04	Confirmed
25	ATT&CK, G1007 Aoqin Dragon, and the ATT&CK groups index	https://attack.mitre.org/groups/G1007/	2026-11-04	Confirmed
26	The Exploit Bulletin newsletter, 9 Oct 2026	https://buttondown.com/exploit-bulletin/archive/the-exploit-bulletin-friday-october-9-2026-3/	2026-11-04	Reported
27	ProFTPD project home page (current releases 1.3.10rc5 and 1.3.9e)	http://www.proftpd.org/	2026-11-04	Confirmed
28	ProjectDiscovery nuclei template for CVE-2015-3306	https://github.com/projectdiscovery/nuclei-templates/blob/main/network/cves/2015/CVE-2015-3306.yaml	2026-11-04	Confirmed
29	Emerging Threats Open ruleset, suricata-7.0.3 emerging-all.rules (no CPFR or CVE-2015-3306 rule)	https://rules.emergingthreats.net/open/suricata-7.0.3/emerging-all.rules	2026-11-04	Confirmed
30	ATT&CK, T1190 Exploit Public-Facing Application (v20, last modified 12 May 2026)	https://attack.mitre.org/techniques/T1190/	2026-11-04	Confirmed

#	Source	URL	Opened	Grade
31	ATT&CK, T1005 Data from Local System	https://attack.mitre.org/techniques/T1005/	2026-11-04	Confirmed
32	ATT&CK, T1505.003 Server Software Component: Web Shell	https://attack.mitre.org/techniques/T1505/003/	2026-11-04	Confirmed
33	CWE-284 Improper Access Control	https://cwe.mitre.org/data/definitions/284.html	2026-11-04	Confirmed
34	CAPEC-650 Upload a Web Shell to a Web Server	https://capec.mitre.org/data/definitions/650.html	2026-11-04	Confirmed
35	D3FEND technique pages: Application Protocol Command Analysis, File Integrity Monitoring, Software Update, Application Configuration Hardening	https://d3fend.mitre.org/technique/d3f:ApplicationProtocolCommandAnalysis/	2026-11-04	Confirmed
36	Lab captures, 4 November 2026: plan.json, 01-setup.txt, 02-test.txt, 03-exposure.txt, 04-mitigation.txt, 05-cleanup.txt and their renders	Lab host captures (screenshots in this page)	2026-11-04	Demonstrated
37	TeamStarWolf library data: data/attack/technique_profiles.jsonl, data/attack/technique_to_d3fend.jsonl, data/weaknesses/cwe.jsonl, data/weaknesses/capec.jsonl and the generated mitre/ pages	https://github.com/TeamStarWolf/TeamStarWolf	2026-11-04	Confirmed

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- All case studies
- CVE Reference
- Notable Incidents
- Threat Actors: the AA26-281A actors have no ATT&CK group object, so no group page is linked
- Malware Families: no malware family is tied to this CVE in the opened record
- Vulnerability Prioritization Reference, Vulnerability Management Reference
- CWE Reference, CAPEC Reference, D3FEND Reference
- The Cl0p MOVEit case study, another file-transfer service exploited at scale, and the Log4Shell case study

- The Ghostcat case study, the lab run whose container appears in the cleanup listing above
- ATT&CK technique pages: T1190, T1005, T1505.003, T1595.002
- CAPEC pages: CAPEC-650, CAPEC-563
- Navigator layers, including this study's layer, proftpd-mod-copy-cve-2015-3306.json on GitHub